

MISSION PROFESSIONNELLE

DOCUMENT DE CADRAGE : PROJET PAPERLESS

Client : Hôpital Sainte-Marie Laboratoire Bioclinique (HSM-Bioclinique)

Cabinet prestataire : NovaSec Consulting

Version : 1.1

Confidentialité : Confidentiel – Usage interne

Auteurs / consultants :

- **Loïc YAMGA** – Chef de mission / Lead cybersécurité & méthodologie EBIOS-RM
- **Samuel KISSI-BI** – Consultant Audit technique & infrastructure
- **Céline NINKE** – Consultante Conformité / RGPD / Gouvernance
- **Keren ADAMU** – Consultante AMOA / Processus métiers & organisation
- **Urich TAMO OUOGUE** – Analyste sécurité / Inventaires & vulnérabilités

DOCUMENT DE CADRAGE

PROJET PAPERLESS RH

TABLE DE MATIERES

TABLE DE MÉTIER.....	2
1. Contexte & Objectifs.....	3
1.1 Contexte général.....	3
1.2 Objectif principal	3
1.3 Objectifs secondaires	3
2. Périmètre du projet	4
2.1 Périmètre IN	4
2.2 Périmètre OUT.....	4
2.3 Hypothèses	4
2.4 Contraintes.....	4
3. Gouvernance & RACI Projet	5
3.1 Gouvernance projet	5
3.2 RACI synthétique.....	5
4. Inventaire des actifs.....	6
4.1 Actifs organisationnels.....	6
4.2 Actifs techniques	6
4.3 Actifs données	6
5. Évaluation de la maturité	7
6. Conformité réglementaire (Tableau)	7
7. Vulnérabilités majeures identifiées	8
8. Besoins fonctionnels & métiers.....	8
9. Exigences de sécurité (extrait)	9
10. Compétences disponibles.....	9
11. Conclusion	10

DOCUMENT DE CADRAGE

PROJET PAPERLESS RH

1. Contexte & Objectifs

1.1 Contexte général

L'Hôpital Sainte-Marie Laboratoire Bioclinique (HSM-Bioclinique) est un établissement hospitalier pluridisciplinaire comprenant un laboratoire d'analyses médicales, une pharmacie interne et plusieurs pôles de soins spécialisés. Depuis plusieurs années, l'établissement cherche à moderniser ses processus internes, optimiser ses échanges documentaires et améliorer la sécurité des données de santé manipulées.

La direction générale souhaite aujourd'hui accélérer la transition vers un fonctionnement paperless tout en renforçant la cybersécurité du système d'information. Cette démarche est motivée par :

- La multiplication des risques cyber (rançongiciels, accès non autorisés, compromission des données de santé)
- Des non-conformités potentielles vis-à-vis du RGPD, de la PGSSI-S et des exigences de la CNIL
- L'hétérogénéité des processus métiers (pharmacie, laboratoire, RH)
- L'utilisation d'outils insuffisamment sécurisés, notamment l'espace Cofor servant au partage de documents RH comme les fiches de paie
- Des pratiques organisationnelles et techniques nécessitant une remise à niveau (absence de MFA, gestion approximative des habilitations, cloisonnement réseau insuffisant, etc.)

Mandat : Le cabinet Nova Sec Consulting, composé de cinq consultants spécialisés, est mandaté pour :

1. Réaliser un audit d'organisation, de conformité et de cybersécurité.
2. Réaliser l'analyse de risques selon EBIOS Risk Manager.
3. Conduire un cadrage complet du projet Paperless.
4. Définir la feuille de route et les recommandations priorisées.

1.2 Objectif principal

Définir le périmètre, les enjeux, les risques initiaux et les attendus du projet Paperless RH, afin d'encadrer l'analyse de risques EBIOS RM et la construction de l'architecture cible sécurisée.

1.3 Objectifs secondaires

- Identifier les vulnérabilités techniques, organisationnelles et réglementaires actuelles
- Évaluer la maturité sécurité de l'organisation

DOCUMENT DE CADRAGE

PROJET PAPERLESS RH

- Mesurer la conformité aux référentiels applicables (RGPD, ISO 27001, eIDAS, NIS2, DORA — volontairement introduit pour cadrage)
- Définir les besoins métiers RH et les exigences de sécurité
- Inventorier les actifs, flux et dépendances critiques
- Définir les rôles et responsabilités (RACI projet)
- Préparer le terrain pour l'analyse de risque EBIOS RM

2. Périmètre du projet

2.1 Périmètre IN

- Processus RH liés à l'émission, distribution et archivage des fiches de paie
- Application de paie actuelle (SIRH)
- Coffre-fort numérique (solution tierce potentielle)
- Portail salarié / intranet RH
- Annuaire interne (AD / Azure AD)
- Méthodes d'authentification (MFA, SSO)
- Données personnelles RH (identité, contrat, rémunération)

2.2 Périmètre OUT

- Dossier médical patient (hors périmètre)
- Applications biomédicales
- Infrastructure réseau externe au service RH
- Dispositifs médicaux

2.3 Hypothèses

- Le personnel dispose d'un accès numérique interne ou externe
- Les salariés disposent d'une adresse personnelle ou professionnelle pour notifications
- Le coffre-fort numérique supporte la signature et le scellement électronique (niveau eIDAS avancé ou qualifié)

2.4 Contraintes

- Délai limité fixé par la direction
- Disponibilité variable des équipes métiers
- Manque de documentation existante
- Hétérogénéité des pratiques métiers
- Infrastructure vieillissante
- Obligations réglementaires strictes (PGSSI-S, RGPD, CNIL, ANS)

DOCUMENT DE CADRAGE

PROJET PAPERLESS RH

3. Gouvernance & RACI Projet

3.1 Gouvernance projet

Rôle	Nom	Responsabilités
Chef de projet (client)	Responsable RH	Pilotage fonctionnel
Responsable Sécurité (client)	DSI	Validation technique
Référent sécurité interne	Anonyme sécurité IT	Liaison sécurité / audit
Consultant Gouvernance	Loïc YAMGA	Conformité, RGPD, cadrage
Consultant SecOps	Samuel KISSI	MFA, IAM, vulnérabilités, sécurité opérationnelle
Consultante données	Céline NINKE	Sensibilité, cartographie données, conformité RGPD
Consultante transformation digitale	Keren ADAMU	Processus métier, optimisation Paperless
Consultant architecture	Urich Tamo	Architecture technique, flux, coffre-fort

3.2 RACI synthétique

Activité	RH	DSI	Référent sécurité	Loïc	Samuel	Céline	Keren	Urich
Cadrage projet	A	C	C	R	C	C	R	C
Analyse conformité	C	C	C	R	C	R	C	C
Inventaire actifs	C	R	C	C	R	C	R	R
Architecture cible	C	A	C	C	C	C	C	R
MFA & IAM	C	A	R	C	R	C	C	R
Cartographie données	C	C	C	R	C	R	C	C

DOCUMENT DE CADRAGE

PROJET PAPERLESS RH

Activité	RH	DSI	Référent sécurité	Loïc	Samuel	Céline	Keren	Urich
Audit vulnérabilités	C	A	R	C	R	C	C	C
Proposition finale	A	C	C	R	C	C	R	R

4. Inventaire des actifs

4.1 Actifs organisationnels

Type	Description	Sensibilité
Processus distribution paie	Actuel : papier, non traçable	Élevée
Processus archivage RH	Papier → archivage local	Élevée
Procédures sécurité RH	Non formalisées	Moyenne

4.2 Actifs techniques

Actif	Description	Criticité
SIRH	Application paie interne	Haute
Coffre-fort numérique	Futur stockage sécurisé	Très haute
AD / Azure AD	Authentification	Très haute
Réseau interne RH	VLAN dédié RH	Haute
Serveur paie	VM interne	Très haute

4.3 Actifs données

Données	Sensibilité	Base légale
Identités salariés	Très élevée	RGPD Art.6
Contrats & salaires	Très élevée	Code du travail
Coordonnées privées	Élevée	RGPD
Bulletins de paie	Très élevée	RGPD + Code du travail

DOCUMENT DE CADRAGE

PROJET PAPERLESS RH

5. Évaluation de la maturité

Domaine	Niveau	Commentaires
Gouvernance	Faible	Aucun comité sécurité RH, pas de PSSI RH
Processus	Faible	Non documentés, non cartographiés
Infrastructure	Moyen	AD fonctionnel mais MFA non généralisé
Applications	Moyen	SIRH non audité récemment
Données	Faible	Classification inexistante
Sécurité opérationnelle	Faible	Pas de journalisation RH
Conformité	Faible	RGPD pas révisé depuis 2020
Continuité	Faible	Pas de PRA spécifique RH

6. Conformité réglementaire

Référentiel	Exigences	Conformité actuelle	Commentaires
RGPD	Registre, DPIA, minimisation	Partiel	DPIA à refaire, sensibilisation absente
ISO 27001	A.5-A.18	Faible	Gouvernance, accès, journalisation manquants
eIDAS	Signature / scellement	Non conforme	Coffre-fort non qualifié
Code du travail	Accès fiche paie par voie électronique	Conforme sous conditions	Coffre-fort nécessaire
NIS2	Gouvernance & cyberséc.	Non applicable mais inspirant	Manquements RH évidents
DORA	Résilience	Non applicable	Ajout volontaire pour pilotage risque
Factur-X	Format de facture électronique structuré (PDF hybride + XML)	Non conforme / Non déployé	Aucun processus de facturation électronique structuré. L'hôpital utilise des PDF simples ou des factures papier. Aucun outil compatible Factur-X n'est en place. Risque futur de non-

DOCUMENT DE CADRAGE PROJET PAPERLESS RH

Référentiel	Exigences	Conformité actuelle	Commentaires
	- Interopérabilité avec Chorus Pro (secteur public) - Archivage électronique probant - Chaîne de confiance et intégrité du document		conformité réglementaire (2026-2027). Opportunité : aligner la démarche Paperless RH avec une stratégie globale de dématérialisation (RH + Finance).

7. Vulnérabilités majeures identifiées

Actif / Processus	Catégorie	Vulnérabilités	Impact	Priorité
Distribution paie papier	Organisationnel	Pas de traçabilité	Fuite ou perte	Haute
SIRH	Applicatif	Pas d'audit sécurité depuis 3 ans	Altération données	Haute
AD / MFA	Technique	MFA non généralisé	Accès non autorisé	Très haute
Archivage	Organisationnel	Papier non sécurisé	Perte, incendie	Très haute
Coffre-fort (futur)	Technique	Sélection solution non sécurisée	Violation massive	Très haute
Réseau RH	Technique	Segmentation floue	Mouvement latéral	Moyenne

8. Besoins fonctionnels & métiers

Domaine	Besoin	Objectif
RH	Automatiser distribution paie	Zéro papier
Sécurité	MFA obligatoire	Réduire risques accès

DOCUMENT DE CADRAGE

PROJET PAPERLESS RH

Domaine	Besoin	Objectif
Données	Classification	RGPD + gouvernance
Architecture	Coffre-fort sécurisé	Réduction risques + traçabilité
Processus	Cartographie complète	Optimisation & conformité
Sensibilisation	Formation RH	Réduire erreurs humaines

9. Exigences de sécurité (extrait)

- MFA obligatoire pour tout accès sensible
- Chiffrement end-to-end pour transmission fiche de paie
- Journalisation centralisée (SIEM)
- Scellement numérique des bulletins
- Séparation des rôles administrateurs RH / IT
- Sauvegarde quotidienne du SIRH
- Authentification SSO compatible OIDC / SAML

10. Compétences disponibles

Ressource	Rôle	Compétences clés	Limites / Manquements
Responsable RH-DSI	Pilotage interne	Connaissance des processus RH & SI	Disponibilité limitée, priorités multiples
Référent sécurité interne	Liaison sécurité / audit	Supervision sécurité RH & infrastructure	Pas d'autorité complète sur l'ensemble du SI
Loïc YAMGA	Chef de mission	Gouvernance, conformité, EBIOS-RM	Dépendance données internes
Samuel KISSI	Consultant SecOps	Infrastructure, MFA, IAM, vulnérabilités	Couverture partielle sur certaines applications
Céline NINKE	Consultante conformité	RGPD, ISO 27001, eIDAS	Manque de documentation existante
Keren ADAMU	Consultante AMOA	Processus métiers, Paperless RH	Disponibilité RH variable
Urich TAMO OUOGUE	Analyste sécurité	Inventaires actifs, flux, architecture	Données parfois partielles

DOCUMENT DE CADRAGE

PROJET PAPERLESS RH

11. Conclusion

Le service RH présente aujourd'hui une maturité faible à moyenne, avec des risques élevés concernant la confidentialité et l'intégrité des données salariales. La transition vers le Paperless représente une opportunité stratégique alignée avec la Transformation Digitale de l'hôpital.

Les manquements identifiés justifient pleinement :

- ✓ Un audit EBIOS RM complet
- ✓ Une refonte de l'architecture SIRH
- ✓ La mise en place d'un coffre-fort numérique sécurisé
- ✓ La généralisation du MFA
- ✓ La mise en conformité RGPD et ISO 27001